

BGYS Dijital Dönüşüm Ofisi Bulguları ve Çözüm Raporu

Rapor Tarihi: 29/07/2026

Uygulama: AsbüBGYS

Kapsam: Yazılımsal ve sistem tarafı güvenlik/işletim kontrolleri

Özet: BGYS üzerinde yapılan kontrollerde canlı debug ayarı, cron/mail endpoint güvenliği, hardcoded gizli bilgiler, silme işlemlerinde HTTP metot kontrolü, yapılandırma parolaları, log yönetimi, PHP/CLI sürüm ayrımı, dosya izinleri, migration yönetimi, saat dilimi ve Apache configtest başlıkları ele alınmıştır. Uygulama tarafında çözülebilen maddeler minimum değişiklik prensibiyle giderilmiş; sistem/mail altyapısı gerektiren başlıklar not olarak ayrılmıştır.

Bulgu ve Çözüm Detayları

#	Başlık	Sorun / Risk	BGYS'de Ne Çıktı?	Yapılan Çözüm	Sonuç
1	Production ortamında debug açık	web/index.php içinde YII_DEBUG=true ve YII_ENV=dev ayarı canlı ortam için risk oluşturmuyordu. Hata detayları, dosya yolları ve hassas uygulama bilgileri kullanıcıya görünebiliyordu.	BGYS canlı uygulamasında debug ekranı gerçekten görünüyordu; kullanıcı ekranında Yii hata detayları ve dosya yolları görüntülenebiliyordu.	Canlı ortam ayarı production mantığına çekildi. Debug kapatıldı, ortam dev yerine prod olacak şekilde düzenlendi.	Canlıda hata detaylarının doğrudan kullanıcıya açılması engellendi.
2	Parse/uyumluluk hataları	Bazı view dosyalarında PHP/Yii sürüm uyumsuzluğu veya hatalı GridView parametreleri nedeniyle sayfa açılışında uygulama çökebiliyordu.	Cihaz türü arama ekranında GridView filterInputOptions parametresi uygulama tarafından desteklenmedi ve Unknown Property hatası üretildi.	Uyumsuz parametreler kaldırıldı/düzeltilti. Arama alanları Yii GridView yapısına uygun hale getirildi.	Cihaz türü ve ilgili arama sayfaları çökmeden çalışır hale geldi.
3	Şifresiz çağrılabilen mail/cron endpointleri	mailat endpointleri login olmadan çağrılabilirdi. Dışarıdan tekrar tekrar tetiklenirse gereksiz mail gönderimi yapılabilirdi.	Mailkapat, cihaz bakım, cihaz garanti ve yeni VM bildirimi endpointleri cron tarafından web üzerinden çağrılıyordu.	Cron endpointleri için gizli cronKey tanımlandı. Anahtar config/params_local.php içine alındı. Cron çağrıları X-BGYS-Cron-Key header'ı ile yapılacak şekilde güncellendi. Kodda hash_equals ile güvenli karşılaştırma eklendi.	Endpointler hâlâ cron tarafından çalışabiliyor; ancak anahtarsız/yanlış anahtarlı çağrılar engelleniyor.

#	Başlık	Sorun / Risk	BGYS’de Ne Çıktı?	Yapılan Çözüm	Sonuç
4	Webhook anahtarının kaynak koduna gömülü olması	vCenter webhook endpointinde sabit anahtar doğrudan controller içinde tutuluyordu. Kaynak kodu erişimi durumunda anahtar açığa çıkabilirdi.	IP kontrolü vardı ancak gizli anahtar kod içinde hardcoded durumdaydı.	Mevcut anahtar değiştirilmeden params_local.php içine taşındı. Kodda hardcoded değer kaldırıldı. hash_equals ile güvenli karşılaştırma yapıldı. IP kontrolü korundu.	Gizli bilgi kaynak kodundan ayrıldı; mevcut akış bozulmadan daha güvenli hale getirildi.
5	Silme işlemlerinde HTTP metot kontrolü	Bazı delete/pdfsil işlemleri GET isteğiyle tetiklenebiliyordu. Bu durum yanlışlıkla veya link üzerinden silme riskini artırıyordu.	Controller’larda VerbFilter import edilmiş olsa da tüm silme işlemlerinde davranış aktif değildi.	Delete ve PDF silme işlemleri POST metoduna alındı. Kullanıcı arayüzündeki silme işlemleri ortak modal onayı ile çalışacak şekilde düzenlendi.	GET ile silme riski azaltıldı; kullanıcıdan açık onay alınmadan silme yapılmıyor.
6	Parola ve bağlantı bilgilerinin yapılandırma açık tutulması	SMTP, LDAP ve veritabanı kullanıcı/parola bilgileri config dosyalarında doğrudan görünüyordu.	config/web.php ve config/db.php içinde hassas bilgiler yer alıyordu.	SMTP, LDAP, veritabanı, mail grupları, cronKey ve webhook anahtarı params_local.php içine taşındı. Kod tarafı bu parametreleri okuyacak şekilde düzenlendi.	Hassas bilgiler merkezi ve yerel yapılandırma dosyasına ayrıldı; kaynak kodundaki görünürlük azaltıldı.
7	SMTP TLS sertifika doğrulaması	SMTP TLS doğrulamasının kapalı olması güvenlik açısından zayıf bir ayardı.	BGYS tarafında güvenli doğrulamaya geçildi. Sunucuda ca-certificates kurulu ve güncel göründü. SMTP STARTTLS testinde TLS bağlantısı kuruldu ancak sertifika doğrulamada “unable to get local issuer certificate” çıktı.	BGYS tarafında verify_peer=false yaklaşımı bırakıldı. Sunucu CA paketi kontrol edildi/güncellendi.	Uygulama tarafı güvenli doğrulama mantığına çekildi. Kalan konu sistem/mail altyapısına not edildi: SMTP sunucusu sertifika zinciri veya kurum içi CA tanımı kontrol edilmeli.
8	Log durumu ve logrotate	runtime/logs/app.log büyüyordu; eski log dosyaları düzenli döndürülmemişti. Logrotate kuralı ilk denemede klasör izinleri nedeniyle çalışmıyordu.	Log klasöründe eski büyük app.log.* dosyaları vardı. logrotate “parent directory insecure permissions” hatası veriyordu.	/etc/logrotate.d/bgys kuralı oluşturuldu/düzeltilti. su asbunet www-data eklendi. Haftalık döndürme, 12 arşiv, compress/delaycompress, notifempty ve copytruncate ayarlandı.	Logrotate testinde hata kalmadı. Yeni loglar düzenli dönecek. Eski logları manuel sıkıştırmaya gerek görülmedi.
9	404 bot/zafiyet taramaları	Loglarda /uploads/index.php, /assets/index.php, /WEB-INF/web.xml, /etc/passwd gibi otomatik zafiyet taraması denemeleri görüldü.	Bu istekler BGYS uygulama hatası değil; bot veya tarama davranışı olarak değerlendirildi. Kaynak IP’ler kurum içi/private ağ adresleri olarak görüldü.	Uygulama tarafında bug olarak ele alınmadı. Fail2ban/WAF/firewall değerlendirmesi sistem/ağ tarafı konusu olarak not edildi. Kullanıcı kontrolünde ilgili IP için ek işlem gerekmediği belirtildi.	Uygulama tarafında yapılacak kritik işlem yok. Gerekirse ağ/güvenlik tarafında izleme veya kural yazılabilir.

#	Başlık	Sorun / Risk	BGYS'de Ne Çıktı?	Yapılan Çözüm	Sonuç
10	PHP aktif sürüm ve CLI eklentileri	Web tarafı PHP 8.0 ile çalışırken terminalde php komutu PHP 8.2'ye gidiyordu. PHP 8.2 CLI tarafında BGYS için gerekli bazı eklentiler eksikti.	Apache/PHP 8.0 tarafında ldap, curl, mbstring, gd, imagick, intl, xml, zip gibi eklentiler vardı. Varsayılan php 8.2 tarafında eksikler görüldü.	Minimum değişiklik yaklaşımıyla sistem varsayılan PHP'si değiştirilmedi. BGYS terminal/Yii komutlarında php8.0 kullanılması kararlaştırıldı.	Web uygulamasında sorun yok. CLI işlemleri için php8.0 yii ... standardı benimsendi.
11	Dosya izinleri ve migration kullanımı	runtime, assets ve uploads izinleri uygundu; migrations klasörü root:root olduğu için normal kullanıcı migration dosyası yazamıyordu.	Veritabanı şema değişikliklerinin kod içinde kalıcı DB komutlarıyla yapılmaması, migration ile kayıt altına alınması gerektiği değerlendirildi.	migrations klasörü asbunet:www-data olacak şekilde düzeltildi. Bu çalışmada eklenen farkındalık eğitimi/quiz ve risk takip kolonları için güvenli migration dosyası yazıldı. Var olan tablo/kolonlar tekrar oluşturulmayacak şekilde tableExists/columnExists kontrolleri eklendi.	Migration başarıyla uygulandı. Bundan sonraki DB şema değişiklikleri migration üzerinden yönetilecek.
12	Sunucu saat dilimi	Eğitim sonuçlarında tarih/saat görünümü kontrol edildi. Web, PHP, Yii, MySQL ve sistem saatinin tutarlı olması gerekiyordu.	Sunucu Europe/Istanbul ve NTP aktifti. MySQL SYSTEM saatini kullanıyordu. PHP 8.0 CLI date.timezone boş olduğu için Europe/Moscow adı görünebiliyordu; saat +03 olduğu için fiili fark yaratmıyordu.	PHP 8.0 CLI timezone Europe/Istanbul olarak düzenlendi. Yii formatter ve Apache PHP timezone zaten Europe/Istanbul idi.	Sistem, web, Yii, PHP CLI ve MySQL saatleri tutarlı hale getirildi.
13	Apache configtest ve ServerName uyarısı	Apache configtest çıktısında global ServerName tanımlı olmadığı için uyarı görölüyordu.	Syntax OK idi; yani kritik Apache yapılandırma hatası yoktu. Uyarı sadece global FQDN tanımsızlığından kaynaklanıyordu.	Global ServerName tanımı eklendi ve Apache configtest temizlenecek şekilde düzenlendi.	Apache yapılandırma testi pürüzsüz hale getirildi; BGYS sanal host ayarları bozulmadı.
14	Yedekleme ve geri dönüş kontrolü	Test ve canlı sunucular için günlük yedek alındığı belirtildi. BGYS için dosya, veritabanı, uploads ve params_local.php kapsamının net olması önemli.	Kullanıcı tarafından test/canlı sunucu ayrımı ve günlük yedek bilgisi paylaşıldı.	Yedek kapsamı ve geri dönüş testi sistem tarafı kontrol listesine alındı.	Yazılımsal değişiklikler tamamlandı; yedek geri dönüş testi sistem operasyonu olarak ayrıca doğrulanmalı.

Kalan Sistem / Altyapı Notları

- SMTP STARTTLS sertifika zinciri için mail/sistem altyapısı kontrolü: “unable to get local issuer certificate” çıktısı incelenmeli.
- 404 bot/zafiyet taramaları için gerekirse ağ/güvenlik tarafında WAF, firewall veya fail2ban değerlendirmesi yapılmalı.
- Yedeklerin sadece alındığı değil, geri yüklenebilir olduğu test edilmelidir.

- LDAPS/AD tarafında firewall veya kurum içi CA gerekiyorsa sistem/AD ekibiyle birlikte ele alınmalıdır.

Sonuç

BGYS uygulama tarafında tespit edilen güvenlik ve işletim bulguları büyük ölçüde giderilmiştir. Cron, gizli anahtar, silme onayları, yapılandırma güvenliği, logrotate, migration ve saat standardizasyonu başlıklarında gerekli düzenlemeler uygulanmıştır. Kalan maddeler uygulama kodundan ziyade sistem, mail, AD/LDAPS veya ağ güvenliği altyapısı kapsamında ele alınmalıdır.

Not: Gizli anahtar, parola, SMTP/LDAP/DB bağlantı bilgileri rapora yazılmamıştır. Bu bilgiler params_local.php içinde tutulmakta ve kaynak koddan ayrılmış durumdadır.